ISO 27001 GRC Management Platform

A learning project for understanding and applying Governance, Risk, and Compliance (GRC) concepts through a small ISO/IEC 27001:2022-inspired web application.

> **Important:** This is an educational project. It is not a certified ISO 27001 compliance product and does not claim that an organization is compliant with ISO/IEC 27001.

Project purpose

The goal of this project is to build a simple system that helps a fictional organization manage information-security risks, controls, Statement of Applicability (SoA) decisions, evidence, reviews, approvals, and audit history.

This project is being developed while learning about:

- Governance, Risk, and Compliance (GRC)
- Information Security Management Systems (ISMS)
- ISO/IEC 27001:2022 concepts
- Risk assessment and treatment
- Security controls
- Evidence management
- Internal review and approval workflows
- Audit trails

Problem being addressed

Small organizations often track risks, controls, evidence, and approvals in separate spreadsheets, documents, and email conversations. This project explores how those activities could be organized in one application.

The intended workflow is:

> **Risk → Control → SoA decision → Evidence → Review → Approval → Audit history**

Planned capabilities

The first version is expected to include:

- Organization and ISMS-scope details
- User roles and permissions

- Risk register
- Risk-to-control mapping
- ISO 27001 control library
- Statement of Applicability records
- Control owners and implementation status
- Evidence records
- Review and approval workflow
- Audit-history records
- Basic dashboard metrics and filters

The scope may change as the project develops. Changes will be recorded in the project documentation.

Intended users

The initial design considers these user roles:

- **Administrator:** Manages users and basic system settings.
- **GRC Analyst:** Creates and maintains risks, controls, and SoA records.
- **Control Owner:** Updates assigned controls and submits evidence.
- **Reviewer/Approver:** Reviews submissions and approves or rejects them.
- **Read-only Auditor:** Views relevant records and audit history.

These roles are design assumptions for the learning project and may be revised after further analysis.

Technology stack

The technology stack will be selected after the requirements and data model are designed.

Planned areas include:

- Frontend: `[to be decided]`
- Backend: `[to be decided]`
- Database: `[to be decided]`
- Authentication: `[to be decided]`
- File storage: `[to be decided]`

The implementation will be written and understood by the project author. AI may be used for explanations, review, and learning support, but not for generating the project implementation.

Documentation

- Project scope
- Requirements: [planned]
- User roles and permissions: [planned]
- Database design: [planned]
- Workflows: [planned]
- Testing notes: [planned]

Current status

Status: Project definition and learning stage

Completed

- Selected ISO 27001 Statement of Applicability and control tracking as the initial project direction.
- Started learning ISO/IEC 27001:2022 and ISMS fundamentals.
- Defined the initial GRC workflow.

In progress

- Finalizing the fictional organization and ISMS scope.
- Identifying initial information assets and risks.
- Designing the requirements and data model.

Planned next steps

1. Finalize the organization profile and ISMS scope.
2. Define the first five risks.
3. Define the first set of controls in my own words.
4. Document the SoA fields and workflow.
5. Design the database entities and relationships.

6. Select the technology stack.
7. Build the first vertical slice of the application.
8. Test the risk-to-control-to-evidence workflow.

Disclaimer

This repository is for learning and portfolio purposes. It does not provide legal, audit, certification, or compliance advice. ISO/IEC 27001 requirements should be interpreted using the official standard and qualified professional guidance where necessary.